OPAUDIT 020 - The security fix that disconnected the skins

Audit ID	2026-10-05-020
Report date	2026-10-05
First observed	A JavaScript-engine defect was answered with a proposed TILEZ skin update despite the owner's explicit rule that reusable engine behavior must never live in a skin. The wrong release target exposed the architectural violation and prompted the fleet-wide review. Repeated live presentation and routing regressions followed the September 28 extraction; the recovery was consolidated as one incident on October 5.
Theme	Two failures compounded. CMS-owned behavior had been placed in independently packaged skins despite an explicit prohibition. The necessary extraction then removed legitimate presentation connections without first inventorying, rebuilding, and proving every bounded CMS-to-skin contract that supplied the visible product.
Surfaces	Schema-v2 public skins; strict public controllers; route compatibility; saved appearance settings; shared assets and components; SMACKPRESS imported content; crawler-file lifecycle; skin packaging; CMS and skin release sequencing.
State	**RECOVERY BOUNDED; MONITORING CONTINUES** The crawler-file lifecycle sub-incident is repaired and fleet-verified. SECAUDIT 059 and 060 are closed with explicit deferred parity debt after independent review. CMS 0.7.822D made both security and parity gates fail-closed; 0.7.823D restored the most visible affected skin families. Whole-fleet pixel-perfect parity is not claimed, and this operability record remains public and updateable.
Human impact	Approximately two weeks of recovery work less than one month before closed beta, damaged trust and morale, lost sleep, and severe autism-related distress reported by the owner, including feeling physically sick. Repeated model-capacity failures prolonged the recovery despite available account quota.
Reporter	Sean identified and repeatedly reproduced the live failures. Codex reconstructed the repository evidence and wrote this report. Model attribution for earlier individual changes remains unproven unless a session record establishes it.
Related	SECAUDIT 059 (skin execution boundary), SECAUDIT 060 (migration-integrity follow-up), pre-migration reference v0.7.772D, controller migration beginning at `c9eb3a9e`, and the generic-layout substitutions in `6cab3a9c`, `2fe6d73d`, and `a28749e5`.
Publication	Published with owner approval on 2026-10-06; updated 2026-10-08 after the later SMACKONEOUT failures exposed the migration's underlying reasoning error. Source recovery remains recorded separately from live-fleet verification.

1. SUMMARY

This incident began with a known architectural rule being broken, not with a newly discovered best practice. The owner had explicitly instructed that database access, request routing, writes, remote calls,

JavaScript engines, and other reusable application behavior must never be placed inside independently packaged skins. Nevertheless, shared behavior was implemented there. The violation surfaced when a JavaScript-engine problem was answered with a proposed TILEZ update. Because the defect belonged to the engine, naming TILEZ as the release target exposed that CMS-owned behavior had been buried in the skin and prompted a review of the entire skin fleet.

Removing that forbidden authority was necessary. The implementation then created a second failure by treating the boundary as a removal exercise instead of a contract migration. Old skin code was stripped out and generic replacement layouts were installed before every route, setting, component, asset hook, interaction, and legitimate visual result had a central replacement and a parity test. Security gates proved that authority was gone. They did not prove that the product still worked.

The predictable result was a long sequence of releases that each restored another missing connection: backgrounds, opacity, navigation, search, complete feeds, image links, static pages, Blogrolls, footers, post counts, saved hero images, clean routes, and skin-specific presentation. The owner was repeatedly told that a repair was done, then found the next regression on the live site. This was an operational failure, not a collection of unrelated cosmetic defects.

2. WHAT FAILED

Failure	Evidence	Consequence
No complete pre-migration contract inventory	Pre-migration GAME ON, AURORA, PARADE, and JIVE TURKEY each had roughly twelve presentation templates/partials. The replacement process produced one generic `layout.php` per skin. The read-only parity diagnostic later found 646 candidate CSS hooks that existed before migration, remained referenced, and were no longer emitted.	Necessary presentation behavior vanished even though the new security boundary itself passed.
Tests proved containment, not parity	Migration/parity suites passed while live skins lacked backgrounds, controls, routes, images, Blogroll styling, footers, and viewer behavior. A route audit found 45 declared-route fallthroughs across 12 skins.	Green gates were incorrectly treated as evidence that the visible product survived the migration.
Generic replacements crossed independent skin contracts	Repository history contains mechanical grid, public, and SMACKTALK restoration scripts and generic replacement commits `6cab3a9c`, `2fe6d73d`, and `a28749e5`.	Distinct skins were changed as a batch without route-by-route and setting-by-setting acceptance evidence.
Release completion was declared too early	From 0.7.773D through 0.7.816D, dozens of development tags and many commits named *Restore* followed the migration. New omissions were repeatedly found only after packaging or live deployment.	The fleet became the parity test environment, multiplying recovery work and owner stress.

Version order was not respected	TILEZ 0.2.59 was packaged and installed while 0.2.58 had not been deployed, despite the owner repeatedly requiring strict sequence. The owner also reported having to finish and deploy CMS 0.7.817D after the assistant stalled, then deploy 0.7.818D.	The version ledger stopped being a trustworthy statement of what had been seen, installed, and verified.
Communication increased rather than reduced load	The owner repeatedly had to distinguish CMS defects from post data, skin defects from shared assets, and source changes from deployed behavior. Repeated capacity errors interrupted the same recovery thread.	The person already doing acceptance testing also had to supervise scope, sequence, and basic state reconstruction.
CMS-owned crawler files were not part of install/update completion	A 25-site read-only audit found `/sitemap.xml` returning 404 on every site although `/sitemap.php` worked; 10 sites lacked `llms.txt`, the other 15 identified old CMS versions, and 6 lacked `robots.txt`. The generator ran only after manual settings/maintenance actions, while the canonical router omitted the advertised sitemap alias and fleet updates never reconciled the files.	Sites could report stale or absent AI/search guidance indefinitely after successful CMS updates. The failure was centralized but presented as fleet drift, adding another unplanned recovery immediately after the owner asked whether the CMS maintained these files.
The first fleet deployment of the crawler repair could not call its own new completion hook	CMS 0.7.820D added the fleet post-update reconciliation call to the same PHP controller that the update replaced. During the update request, PHP continued executing the already-loaded 0.7.819D controller, so the newly written call was not available until a later request. Version checks passed while the intended repair silently did not run on 24 spokes.	The release was successfully installed but functionally unsuccessful. This is a bootstrap design defect in the updater, not a deployment omission by the owner.

3. REPRESENTATIVE REGRESSIONS

- SMACKPRESS-imported images lost their larger-image/lightbox association, and a repair initially targeted the wrong layer instead of the imported post contract.
- TILEZ images widened outside their original footprint on hover; its configured standard footer was present but hidden by a shared drawer controller that claimed the same generic identifier.
- GAME ON lost animated framed-image state, direct photograph routing, background content on secondary pages, styled Blogroll and About presentation, saved About imagery, ordinary footer flow, and the distinction that its landing page already is its archive.
- AURORA's engine remained registered but its intended visibility and post-viewer relationship were not adequately acceptance-tested. JIVE TURKEY's suspected scrim regression was investigated and not confirmed; the saved value was zero.

- Legacy public links and configured menu records continued to use `?view=` and PHP filenames rather than clean owner-facing paths such as `/diary` and `/blogroll`.
- The CMS advertised `/sitemap.xml` in generated robots files without ever installing that route, and failed to regenerate `robots.txt` and `llms.txt` during ordinary or fleet updates.

4. ROOT CAUSE

An explicit ownership rule was disregarded. Reusable JavaScript-engine and application behavior was placed in independently packaged skins even though the owner had specifically prohibited that architecture. The proposal to repair an engine defect by releasing TILEZ was not merely an imprecise status message; it was the observable clue that the forbidden coupling existed. That clue initiated the fleet-wide investigation.

The project optimized for the absence of forbidden code and failed to specify the presence of required behavior. A skin-security migration has two acceptance conditions: the old authority must be gone, and every legitimate result that authority used to produce must arrive through a bounded central contract. Only the first condition had a strong gate.

The work was released in fragments before a representative fleet matrix was complete. A source test, a DOM token, or one repaired site was repeatedly allowed to stand in for live route and interaction parity. That made each release another discovery step instead of a controlled rollout.

The release process did not honor the owner's sequential constraint. This was not harmless bookkeeping. Strict order is both a technical traceability requirement and an accessibility requirement for this owner. Repeating the violation after it had been explicitly explained materially worsened the incident.

5. CORRECTIVE ACTIONS

1. For every skin family, maintain a pre-migration ledger of routes, settings, emitted structure, shared assets, interactions, and saved-value behavior. Each item must be classified as restored, intentionally retired with owner approval, or still open.
2. Test both halves of every security migration: forbidden authority is absent; required output and behavior are present. A security ratchet alone is never a parity gate.
3. Require browser acceptance for landing, detail/modal, static page, Blogroll, archive semantics, navigation, footer, responsive behavior, and the skin's defining interaction before publishing a skin recovery.
4. Keep releases sequential: create N, package N, deploy N, verify N, then and only then create N+1. A skipped build requires the owner's explicit recorded cancellation; an agent cannot infer it.
5. Separate diagnosis, source repair, package publication, installation, and live verification in every status report. Never use “fixed” when only source tests have passed.
6. Do not bulk-rewrite forkable skins. Shared behavior belongs in audited CMS assets and bounded view models; each skin's presentation remains independently reviewed.
7. Record the human cost and accessibility consequences in incident closeout, not only the code delta and test count.

6. CURRENT RECOVERY EVIDENCE

Item	State	Evidence
CMS 0.7.819D	Deployed and bounded verification complete	The hub and 24 connected sites report 0.7.819D. Clean routes, GAME ON pages, standard footer flow, and the targeted imported-post repair were live-verified.
CMS 0.7.820D	Deployed; repair failed on 24 spokes	Package SHA-256 `d0bba184112afb424e19bfcd46a45764c01f8a6a09609e57af2015070104c7c3`, source commit `5f1fc9ee260109a708b28f6aadd113764963aba0`. Authenticated status checks reported 0.7.820D on all 24 spokes; the hub is also publicly identified as 0.7.820D.
CMS 0.7.821D	Packaged, deployed, and fleet-verified	Sequential package source commit `85f7b66819092cbf8ab4e0868618be2443257ae8`; manifest and downloaded ZIP SHA-256 both `b4c97220bec8705aeff4ebafe21913140e83a7cb42c3106fdffec571f8a5b1f0`. The authenticated hub dashboard reports the hub and all 24 spokes active on exactly 0.7.821D with no pending update.
GAME ON 0.1.24	Deployed and bounded verification complete	Presentation-only template; landing, direct photograph modal, Blogroll, About page, saved hero/background state, animated frame state, and standard footer flow live-verified.
TILEZ	Unchanged	Remains 0.2.59. The clean-route and idempotent import-repair work is CMS/tool-owned.
Security boundary	Gate passes	A draft template-side validation change was rejected by the fleet ratchet before release; validation was moved to core and the ratchet then passed.
Crawler repair deployment	Closed in 0.7.821D	The 0.7.820D first-request failure remains part of the incident record. Its sequential repair makes deployment a two-request operation so finalization loads newly installed code. Post-deployment HTTPS verification passed on 25 of 25 sites: every site serves `robots.txt` naming its public `/sitemap.xml`, `llms.txt` identifying 0.7.821D, `/.well-known/security.txt`, and valid XML from `/sitemap.xml`.
Whole-fleet parity	Open	Neither this candidate nor this report represents all remaining skin findings as closed.

Strict photo/archive CMS contract	Source repaired and regression-verified; not yet published	The October 6 follow-up found that the strict controller accepted `?page=N` while the existing infinite-feed engine requested `?p=N`, causing later requests to repeat page one. It also found an arbitrary 5,000-photograph repository ceiling that made the older half of a roughly 10,000-photo SLICKR archive unreachable. The CMS now normalizes both page forms, prepares justified rows from a complete lightweight published-photo inventory, preserves the established manual/date order, and exposes only one bounded 25-row page to the skin. It also owns album/category archive filters and counts, photograph neighbours and boundaries, album/tag memberships, and formatted technical metadata formerly assembled around skin templates. A 6,001-photo regression proves that page two advances and the final photograph remains reachable.

7. OCTOBER 6 REMEDIATION ADDENDUM

The initial recovery statement was still too optimistic about SLICKR. The row-packing mathematics had been moved into the CMS, but the complete request contract had not. The client requested subsequent batches with `?p=N` while the strict controller read only `?page=N`; a successful fetch could therefore repeat the first page indefinitely. Separately, a generic 5,000-item safety ceiling was reused for a lightweight layout inventory even though the live archive contains roughly twice that number. Both defects were capable of passing the existing presentation-token test.

The repair keeps authority on the correct side of the boundary. The public repository performs a narrow, read-only query for published photograph identity, thumbnail, dimensions, and established ordering. The controller calculates the complete row geometry, slices it into bounded pages, and gives the skin only the requested prepared rows. The same bounded controller now supplies filtered archive results and counts plus each photograph's navigation destinations, album and tag memberships, and formatted technical details. No database handle, query, request parsing, metadata formatting, or paging rule returns to the skin. Obsolete `fjGallery` declarations and the exact SLICKR presentation restoration remain separate skin-package work and are not represented here as complete.

8. CLOSURE GATE

The failed 0.7.820D first-upgrade behavior was repaired in strict release order, and all 25 audited sites answer the public sitemap route and carry current CMS-generated crawler files. The formal security follow-up received an independent adversarial review. That review found a HIGH filename-based gate bypass and proved that the original parity tests asserted structure rather than successful coverage. Both findings closed in 0.7.822D. The owner accepted the remaining 43 strict-route fallthroughs and 611 presentation-hook candidates as named, ratcheted debt rather than pretending they were either zero or 654 confirmed live defects.

CMS 0.7.823D then restored the WordPress mosaic import, TILEZ navigation spacing, GAME ON and INSTANT CAMERA solo presentation and navigation, and grid-family photo modals. The 166-program regression directory and the targeted security, gate-wiring, and parity gates pass. This moves the recovery

from open-ended emergency work to bounded monitoring. It does not claim a fresh live visual sweep of every route on every site.

9. ADDITIONAL CRAWLER-FILE ADMISSION

We said SnapSmack sites maintained their own SEO and agent-facing files before checking the fleet. They did not. The generator existed, but we had not connected it to install or update completion, and the route it advertised did not exist. This should have been a release invariant from the first version that emitted `Sitemap: .../sitemap.xml`. The owner found the missing control by asking a basic product-responsibility question during an already exhausting recovery.

The first attempted repair then repeated the operational mistake in a subtler form. Version 0.7.820D was packaged, deployed, and reported successfully by the fleet, but the reconciliation callback was added inside the controller being replaced. The active update request was still executing the old controller already loaded into memory, so the new callback could not run on that first upgrade. Only the hub's separate update path completed reconciliation. Post-deployment verification found 24 of 25 sites still unrepaired. A reported version match is therefore not evidence that update-completion behavior ran.

Sequential CMS 0.7.821D corrected that bootstrap defect by separating installation and finalization into two authenticated requests. The second request necessarily loads the newly installed controller before reconciling public files. The signed package and source commit were independently matched, the hub and all 24 spokes reported 0.7.821D, and the repeated public audit passed every crawler-file condition on all 25 sites. This closes the crawler-file sub-incident without claiming that the wider skin-parity incident is closed.

10. OCTOBER 7 SEQUENTIAL-RELEASE CONTROL FAILURE

The sequential-release corrective action above failed again. CMS 0.7.826D was committed and tagged, but it was not packaged, deployed, and verified before work advanced to 0.7.827D. Version 0.7.827D was then packaged and deployed while the release history still lacked a 0.7.826D package. A sequential source tag did not satisfy the owner's requirement: the required order was candidate, package, deployment, and live verification for N before creating N+1.

This repeat is recorded as an accessibility failure, not a preference or an untidy release ledger. The owner had repeatedly explained that strict sequence is important to him and has disclosed Asperger's. After this recurrence he reported that these violations affect him severely enough that he does not sleep. Continuing to rely on agent memory and a tag-only guard after that requirement was known was operationally and humanly unacceptable.

The corrective control therefore cannot stop at checking the next available Git tag. Before work begins on N+1, the release record for N must prove all four stages: the exact sequential version was tagged, its signed package was published, the fleet installed it or the owner explicitly cancelled it, and live verification completed. An unpublished tag is not a completed release, and silence is not cancellation.

11. PLAIN ADMISSION

We made a necessary security change in an unsafe operational way. We removed code from skins before proving that the CMS supplied everything those skins legitimately needed. We relied on tests that could pass while sites were visibly broken. We released too many partial repairs, broke version order after being told not to, and left the owner to find and supervise regressions that should have been caught before deployment. The resulting loss of time, trust, and wellbeing was avoidable.

12. OCTOBER 8 ADDENDUM: RELOCATION WAS MISTAKEN FOR PERMISSION TO REDESIGN

The owner reasonably understood the boundary migration as a relocation: code that was on the wrong shelf would be moved to the right shelf, with the same visible result and a narrow connection from the skin to its new CMS-owned home. That was the required model. Instead, the migration treated the architectural destination as permission to reinterpret the presentation. Repeated and skin-specific markup was mistaken for duplication to be normalized. Proven renderers were replaced with generalized skeletons, including the SMACKONEOUT substitution in `2fe6d73d` and the analogous SMACKTALK substitution in `a28749e5`. Those replacements could satisfy structural and security assertions while rendering title lists instead of photographs, treating a solo landing page as an archive, and dropping the hooks and semantics that made each skin itself.

This was not a failure to understand where authority belonged. It was a failure to treat established behavior as conserved during the move. The implementation optimized for a cleaner abstraction and silently spent compatibility to obtain it. Because the tests asked whether forbidden authority was absent and expected files or tokens existed, rather than whether representative sites still rendered and behaved the same, the abstraction looked successful until the owner saw the live pages. Installation, package signing, and the stricter boundary did not cause the visible destruction; they delivered code in which the destruction had already been written.

Permanent conservation rule: transplant, do not reinterpret. A security, ownership, or architecture migration is behavior-preserving unless a separate visible change is explicitly approved. Existing rendered HTML, CSS hooks, assets, routes, queries, ordering, loading cost, interactions, saved-setting behavior, and every skin-specific oddity are protected requirements. Repetition is not permission to generalize it. “Move” means relocate the working implementation behind a bounded adapter; it does not mean replace it with a generic approximation.

Before such a migration ships, representative real sites must prove both sides of the contract: forbidden authority is gone, and established output and behavior remain. Tests must inspect image-bearing rendered output and route semantics, not merely filenames, classes, hooks, or successful requests. Where parity cannot be demonstrated, work stops and the difference is presented to the owner before substitution. Architecture remains subordinate to the product people already use.

13. OCTOBER 15 ADDENDUM: INLINE CSS CROSSED THE SKIN BOUNDARY

A fleet source audit found 27 inline `style` attributes across 12 schema-v2 skin templates: AURORA, GAME ON, GLIDE, HEURISTIC, INSTANT CAMERA, JIVE TURKEY, PARADE, RATIONAL GEO, SLICKR, SLIDERS, SUDDEN IMPACT, and THE GRID. This repeated the same category of control failure: an explicit presentation boundary existed, but neither the work nor the package gate enforced it.

The source remediation removes those style attributes without discarding the saved values they carried. Templates now expose bounded frame and geometry values as inert `data-*` attributes; each owning skin's external `style.css` consumes those values and retains fallback defaults. CMS view models now supply structured frame presentation data rather than serialized CSS declarations. Fixed SLICKR geometry moved directly into its stylesheet.

A repository regression now scans every PHP-capable file below `skins/` and fails if a style element or HTML style attribute returns. Grid-family render tests also assert that per-image frame data survives the handoff and that rendered skin routes do not emit style attributes. This entry records source remediation and test evidence only. It does not claim packaging, deployment, or live cross-browser verification.